



Cloud Security Posture Management

Runbook – Remediation

IAM User Should Not Be Inactive for More Than 90 Days

Control ID	IAM-047
Control Name	IAM User should not be inactive for more than 90 days
Severity	Medium
Audience	Application Teams · Cloud Platform · Cloud Security
Tooling	Wiz Cloud Security Platform
Compliance	CSA CCM v4.0.5 → IAM-09 (Access Control)
Version	1.1
Owner	Cloud Security Team
Last Updated	May 2026
Review Cycle	Quarterly

Table of Contents

Table of Contents 1

1. Overview.....3

2. Description 3

3. Objective3

4. Triage Process.....3

 4.1 Identify Affected Users (Wiz)4

 4.2 Categorize Users.....4

5. Manual Mitigation – AWS Console4

5.1 Deactivate Access Keys	4
5.2 Disable Console Access	5
5.3 Delete IAM User (Only If Fully Approved)	5
6. Mitigation – AWS CLI.....	6
Step 1 — Identify access key IDs (required before disabling)	6
Step 2 — Disable access key(s)	6
Step 3 — Disable console access (delete login profile)	6
Step 4 — Verify inactivity independently (optional)	6
7. Mitigation Using Terraform (IaC)	7
7.1 Disable Console Access Using Terraform	7
7.2 Remove Access Keys Using Terraform	7
7.3 Recommended Terraform Workflow	7
8. Mitigation Using CloudFormation (IaC)	8
8.1 Disable Console Access Using CloudFormation.....	8
8.2 Remove Access Keys Using CloudFormation	9
8.3 Recommended CloudFormation Workflow	9
9. Document Exception.....	9
10. Detective Control	10
10.1 Credential Report — Key Columns	10
10.2 Generate Credential Report (AWS Console)	11
11. Validation and Success Criteria.....	11
12. References.....	11

1. Overview

Detection Tool	Wiz Cloud Security Platform
Wiz Rule	Cloud Configuration Rules Wiz
Detective Control	AWS IAM Credential Reports

2. Description

This control identifies AWS IAM users — both human and service accounts — that have been inactive for more than 90 days, based on last console login and access key usage as reported by AWS IAM credential reports.

Inactive users often represent orphaned identities whose credentials remain valid, increasing the risk of unauthorized access and non-compliance. The control supports identity hygiene by enabling periodic review and remediation of unused IAM users.

This control is detective in nature. AWS does not provide a managed Config rule for enforcing IAM inactivity thresholds; detection is achieved through AWS IAM credential reports analyzed by the Wiz Cloud Security Platform.

3. Objective

This runbook provides standardized operational guidance for security and cloud operations teams to:

- Validate inactivity findings in Wiz
- Assess business ownership and risk for each affected user
- Safely disable or remove unused IAM credentials
- Handle approved exceptions with documented compensating controls

The goal is to ensure all inactive IAM users are either remediated, formally approved as exceptions, or decommissioned — reducing the attack surface and maintaining a strong security posture across AWS accounts.

4. Triage Process

 **General triage principles** — including how to assess whether a finding is valid, a false positive, or an accepted risk — are defined in the [Master Template – Remediation SOP](#). Complete that review before proceeding with the IAM-047-specific steps below.

4.1 Identify Affected Users (Wiz)

1. Navigate to Wiz → Cloud Configuration Findings and filter by the rule: "IAM User should not be inactive for more than 90 days".
2. Export the list of affected IAM users.
3. Collect the following details for each user:
 - IAM username
 - AWS account ID
 - Last activity — check credential report fields: **password_last_used**, **access_key_1_last_used_date**, **access_key_2_last_used_date**
 - User creation date
 - Ownership / team tags
 - Active key status: **access_key_1_active**, **access_key_2_active**

4.2 Categorize Users

Review each affected user and assign one of the following categories before proceeding:

Category	Description	Next Action
A – Safe to Disable / Delete	Test, demo, former-employee, or temporary accounts with no active business purpose.	→ Proceed to Section 5, 6, 7, or 8
B – Requires Investigation	Service accounts, shared users, break-glass users, or accounts with unclear ownership.	→ Contact application owner and confirm purpose before acting
C – Business-Critical / Exception	Audit-mandated accounts or users with a valid business reason to remain active.	→ Proceed to Section 9 (Exception Process)

 **Before acting, confirm the user's:** purpose · owner · type (human or service) · attached permissions · MFA status
If any of these cannot be determined, pause and contact Cloud Security before proceeding.

5. Manual Mitigation – AWS Console

Use this approach for one-off remediations or when the IAM user is not managed by IaC. All console actions are reversible until the delete step in Section 5.3.

5.1 Deactivate Access Keys

✓ This action is safe and reversible. The user object and all configuration remain intact.

1. Navigate to AWS Console → IAM → Users and select the affected IAM user.
2. Go to the Security credentials tab.
3. Confirm that last-used dates for Console sign-in and Access keys exceed 90 days.
4. Under Access keys, for each active key:
 - Click Actions → Make inactive
 - Confirm the action

Result: Access key status changes to Inactive. The key can no longer be used but the user object and key ID remain intact — this action is reversible.

⚠ Monitor for 7–14 days after deactivation before proceeding to disable console access or deletion. Document any service impact observed during this period.

5.2 Disable Console Access

Use when Wiz shows the console password has not been used for ≥90 days, or when the user requires only programmatic access.

1. Go to: IAM → Users → [User] → Security credentials tab.
2. Locate the Console sign-in section.
3. Click Disable console access.
4. Confirm the action.

Result: Console login is removed. Programmatic access (access keys) is unaffected.

5.3 Delete IAM User (Only If Fully Approved)

Delete only when all three conditions are met:

- Credentials disabled (per 5.1 / 5.2) and monitored for 7–14 days with no service impact
- No active usage or application dependency observed
- Business owner approval obtained

Follow these steps in order:

1. Remove user from all IAM groups
2. Detach all managed policies
3. Delete all inline policies
4. Delete all access keys

5. Remove MFA devices (if any)
6. Delete login profile (skip if the user never had console access — no profile will exist)
7. Delete the user

6. Mitigation – AWS CLI

Run the following commands in sequence. Ensure you have the necessary IAM permissions before proceeding.

Step 1 — Identify access key IDs (required before disabling)

```
aws iam list-access-keys --user-name <USERNAME>
```

Step 2 — Disable access key(s)

Repeat for each active key returned in Step 1:

```
aws iam update-access-key --user-name <USERNAME> --access-key-id <ACCESS_KEY_ID> --status Inactive
```

Step 3 — Disable console access (delete login profile)

```
aws iam delete-login-profile --user-name <USERNAME>
```

i If the user never had console access, this command returns a `NoSuchEntity` error — this is expected and can be safely ignored.

Step 4 — Verify inactivity independently (optional)

Generate and download the IAM credential report to cross-check findings:

```
aws iam generate-credential-report
# Wait for status: COMPLETE, then download:
aws iam get-credential-report --query Content --output text | base64 --decode > credential_report.csv
```

 AWS limits credential report generation to once every 4 hours. If the command returns STARTED or the report appears stale, wait and retry.

7. Mitigation Using Terraform (IaC)

Use this approach when IAM users and credentials are managed as Infrastructure as Code. Terraform enforces remediation by removing or preventing creation of unused credentials rather than disabling them in place.

Importing manually created users: If the IAM user was not originally provisioned via Terraform, import it into state before proceeding — otherwise Terraform may attempt to create a duplicate or fail.

```
terraform import aws_iam_user.this <USERNAME>
```

7.1 Disable Console Access Using Terraform

If the IAM user login profile is managed in Terraform, remove or conditionally disable it:

```
resource "aws_iam_user_login_profile" "this" {  
  count = var.enable_console_access ? 1 : 0  
  user  = aws_iam_user.this.name  
}
```

7.2 Remove Access Keys Using Terraform

Set the access key resource count to zero to enforce removal of unused keys:

```
resource "aws_iam_access_key" "this" {  
  count = var.create_access_key ? 1 : 0  
  user  = aws_iam_user.this.name  
}
```

7.3 Recommended Terraform Workflow

1. Wiz identifies unused IAM credentials.

2. Security team validates business and operational impact.
3. If the user is not in Terraform state, run terraform import (see note above).
4. Update Terraform variables to disable console access or remove access keys.
5. Run terraform plan — review the proposed changes carefully.
6. Obtain peer review / approval of the plan output.
7. Run terraform apply to enforce the change.

8. Mitigation Using CloudFormation (IaC)

Use this approach when IAM users and credentials are managed via CloudFormation. Remediation is enforced by removing IAM resources from the stack or conditionally preventing their creation.

Drift detection: If credentials were modified manually outside of CloudFormation after initial provisioning, the stack's view of the resource will be stale. Run a drift detection check before executing a change set.

AWS Console → CloudFormation → Stack → Stack actions → Detect stack drift

8.1 Disable Console Access Using CloudFormation

Remove the AWS::IAM::LoginProfile resource or conditionally control its creation using Conditions:

```
Parameters:
  EnableConsoleAccess:
    Type: String
    AllowedValues: [true, false]
    Default: false

Conditions:
  CreateConsoleAccess: !Equals [!Ref EnableConsoleAccess, true]

Resources:
  IAMUser:
    Type: AWS::IAM::User
    Properties:
      UserName: example-user

  IAMUserLoginProfile:
    Type: AWS::IAM::LoginProfile
    Condition: CreateConsoleAccess
    Properties:
```

```
UserName: !Ref IAMUser
PasswordResetRequired: true
```

8.2 Remove Access Keys Using CloudFormation

Remove or conditionally exclude the AWS::IAM::AccessKey resource:

```
Parameters:
  CreateAccessKey:
    Type: String
    AllowedValues: [true, false]
    Default: false

Conditions:
  CreateAccessKeyCondition: !Equals [!Ref CreateAccessKey, true]

Resources:
  IAMUser:
    Type: AWS::IAM::User
    Properties:
      UserName: example-user

  IAMUserAccessKey:
    Type: AWS::IAM::AccessKey
    Condition: CreateAccessKeyCondition
    Properties:
      UserName: !Ref IAMUser
      Status: Active
```

8.3 Recommended CloudFormation Workflow

1. Run drift detection on the stack before making any changes.
2. Security team validates business and operational impact based on Wiz findings.
3. Update CloudFormation parameters or templates to disable console access or remove access keys.
4. Create a change set and review the proposed changes carefully.
5. Obtain peer review / approval of the change set.
6. Execute the stack update to enforce remediation.

9. Document Exception

Use the exception process when an IAM user must remain active for a valid, documented business reason (Category C users from Section 4.2).

Exception Process: Submit and manage exceptions using the formal exception governance process. All required fields, approval workflows, and expiration timelines are defined there.

→ [Wiz CSPM Exception Governance](#)

At minimum, every exception must include:

- Business justification for continued inactivity
- Approver name and approval date
- Exception expiration date (maximum 180 days — must be reviewed and renewed if business need persists)
- Compensating controls in place (e.g., MFA enforced, permissions scoped, activity alerting enabled)

10. Detective Control

This section describes how IAM user inactivity is detected and how to independently verify findings using AWS-native tooling.

This control cannot be enforced using an AWS Config managed rule. Detection is achieved through AWS IAM credential reports, which provide last-used information for console passwords and access keys. Wiz continuously analyzes this data to identify users with no activity exceeding 90 days and generates actionable findings for remediation.

10.1 Credential Report — Key Columns

When reviewing the downloaded credential report CSV, focus on the following columns:

Column	What It Tells You
password_last_used	Last time the user logged into the AWS console
access_key_1_last_used_date	Last time access key 1 was used to make an API call
access_key_2_last_used_date	Last time access key 2 was used to make an API call
access_key_1_active	Whether access key 1 is currently enabled (true/false)
access_key_2_active	Whether access key 2 is currently enabled (true/false)

10.2 Generate Credential Report (AWS Console)

1. Log in to the AWS Management Console.
2. Go to Services → IAM.
3. In the left navigation, click Credential report.
4. Click Generate report and wait for status to show Complete.
5. Click Download report to save the CSV.

 The credential report can only be generated once every 4 hours. If the Generate report button is unavailable or the report appears stale, wait and try again.

11. Validation and Success Criteria

After completing remediation, verify success using the following checklist before closing the finding.

☐	Re-check the specific resource in Wiz and confirm the finding status is Resolved or No longer applicable.
☐	Confirm no service disruption or application alerts were triggered in the 7–14 days following credential deactivation.
☐	If the user was deleted, confirm the user no longer appears in the IAM credential report.
☐	Update the Finding Management Tool with the remediation outcome and date.
☐	If an exception was filed (Category C), confirm it is logged in the exception register with an expiration date.
☐	Update runbook or IaC documentation if any environment-specific steps were required.

12. References

- [Wiz Cloud Configuration Findings Documentation](#)
- [AWS IAM Credential Reports](#)
- [CSA CCM v4.0.5 Cargill Framework \(Wiz\)](#)
- [Cloud Security Navigator \(CSN\)](#)
- [Wiz CSPM Exception Governance](#)
- [Master Template – Remediation SOP](#)
- [CSPM Finding Management Tool](#)